# Cognito as Auth Server

| | |
|---|---|
| **Title** | **Cognito as Auth Server** |
| **Identifier** | TRA-CASM-0003 Cognito as Auth Server |
| **Security Domain** | CASM |
| **Status** | Approved |
| **Version** | **v1.0** |
| **Technology landscape** | AWS Cognito, API Gateways |
| **Parent** | N/A |
| **SubArticles** | N/A |

## Contents

# Introduction

This Technical Reference Architecture (TRA) defines the standard for using AWS Cognito as an Authorization Server (AuthZ server) in federated authentication scenarios with external Identity Providers (IdPs).

In the context of OAuth 2.0 and OpenID Connect (OIDC), the Authorization Server is the component responsible for issuing security tokens (Access Tokens, Refresh Tokens, ID Tokens) to client applications on behalf of a resource owner (the user).

This document focuses exclusively on this Authz Server capability, the mechanisms of token issuance, validation, and the required application integration patterns. It deliberately excludes the broader topics of identity lifecycle management, governance, and provisioning, focusing purely on the OAuth 2.0/OIDC protocol implementation.

This architecture will co-exist with other approved Authorization Servers, and this TRA provides the definitive technical guidance for development teams choosing to leverage Cognito for this purpose.

The primary goals of this architecture are:

- **Standardize API Security:** Provide a single, consistent, and secure method for user-facing applications to gain access to protected internal APIs.
- **Developer Enablement:** Offer clear, prescriptive patterns for developers to integrate new and existing applications (SPAs, web apps, mobile, services) with a central Authz Server.

← Contents

## Scope

## Core Concepts and Components

## Architectural Overview

## Quick Integration Guide for Architects

## Runtime Architecture

## Deployment and Scalability

## Performance and Reliability

## Anexes

## References